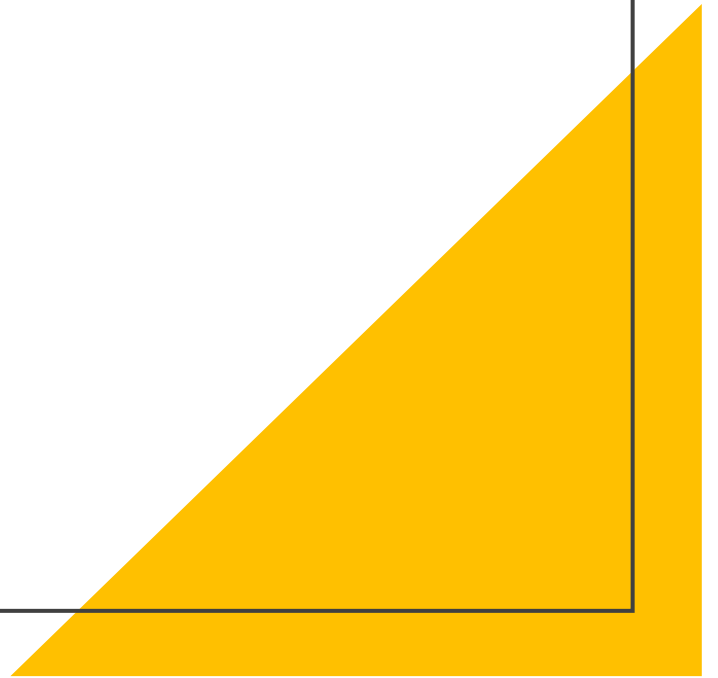


Sociotechnical Security

CS 8803/4803

Professor Veronica Rivera

Lecture 5 – Authentication 1 (Problems)



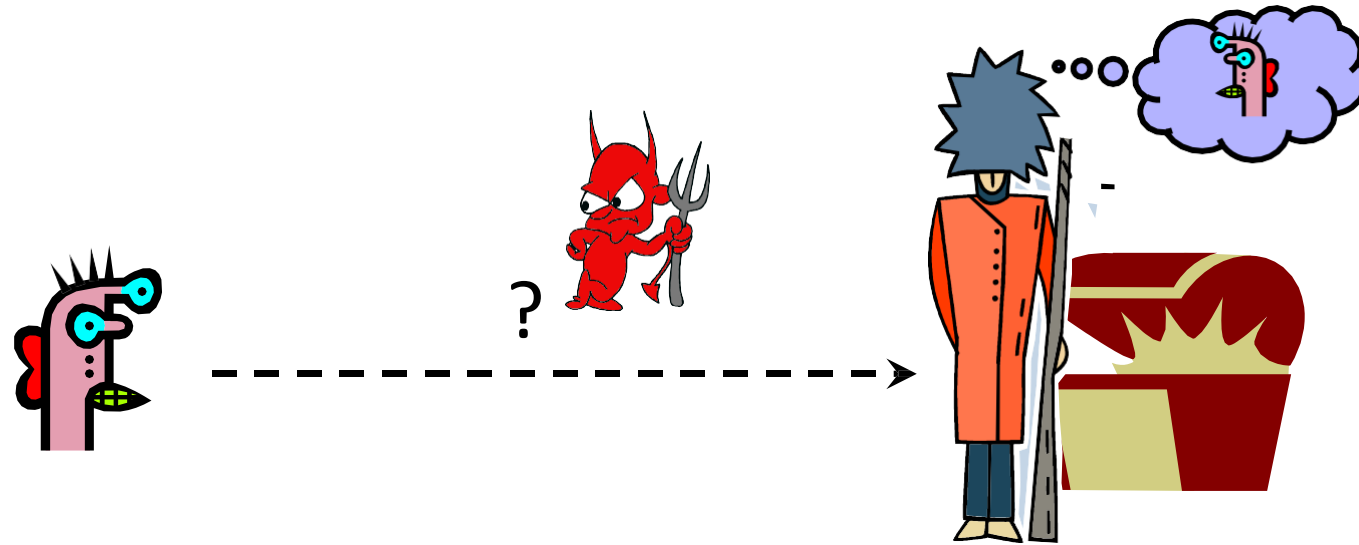
Last time

- Sociotechnical abuse vectors
 - Digital safety equivalent of attack vectors in traditional security
- Read and discussed a paper that used web crawling to measure prevalence and ease of access of spyware tools with potential for use in IPS
 - First in-depth study of the IPS spyware ecosystem
- We will come back to IPS & digital safety in a few weeks

Today

- Authentication
 - Beginning of 3 weeks discussing topics in usable security and privacy
- Lecture on human-centered password security risks
- Discuss the two readings:
 - Users Are Not the Enemy
 - A Large-Scale Study of Password Habits
- Quick logistics
 - Detailed instructions for project proposal are up on the website
 - Leading discussion assignments up on website – change to presentation length

Basic Problem



How do you prove to someone that
you are who you claim to be?

Any system with access control must solve this problem.

Many Ways to Prove Who You Are

- “Something you know”
 - Passwords
 - Answers to questions that only you know
- “Something you have”
 - Secure tokens, mobile devices
- “Something you are”
 - Biometrics

Problem 1: Weak passwords

- 2025: 80% of basic Web Application attacks used stolen creds
 - 56% used brute forcing of weak passwords
- 2025: ~15% of network intrusions used some sort of stolen/weak passwords
 - In 2022, was 50%!
- Source: Verizon Data Breach Investigations Report
 - <https://www.verizon.com/business/resources/reports/dbir/#archive>
 - Lots of interesting data here.

Weak password distribution



- RockYou hack
 - “Social gaming” company
 - Database with 32 million user passwords from partner social networks
 - Passwords stored in the clear
 - December 2009: entire database hacked using an **SQL injection attack** and posted on the Internet
 - One of many such examples!

[illegible]

Default Passwords

- Examples from Mitnick's "Art of Intrusion"
 - U.S. District Courthouse server: "public" / "public"
 - NY Times employee database: pwd = last 4 SSN digits
- Mirai IoT botnet
 - Weak and default passwords on routers and other devices

Problem 2: Shared passwords

Why are shared passwords bad?

Process:

1. Johnny makes up password, gives it to Google
2. Johnny also gives the same password to his HOA website
3. Google doesn't get breached, HOA does
4. Hacker tries Johnny's password at many sites, including Google

The attacker only has to break the weakest site

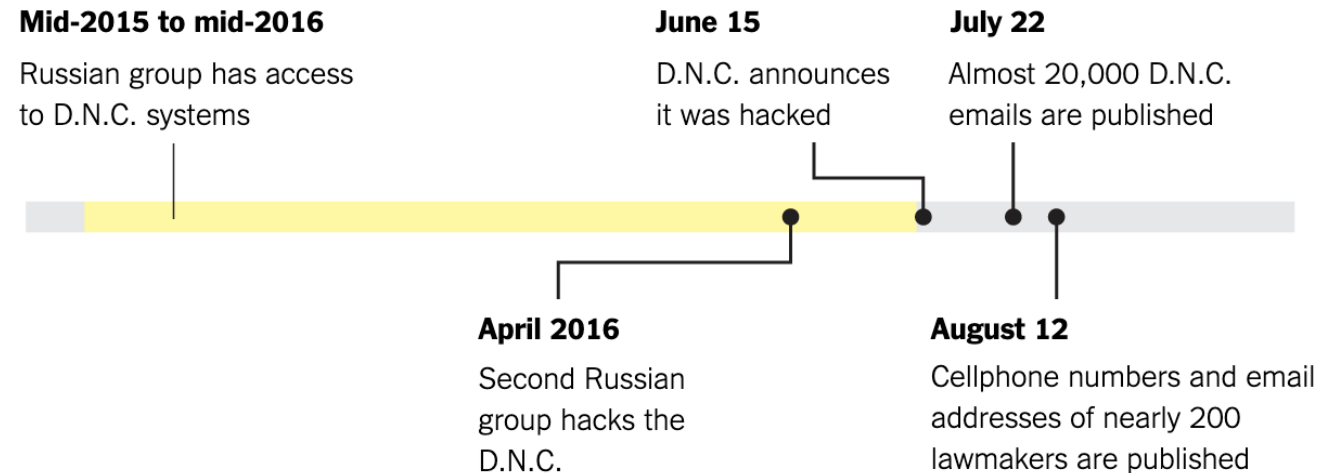
Problem 3: Users give adversary their password

- In 2025: Phishing appeared in 36% of all data breaches
- Process:
 - Hacker makes facebook.com
 - Sends link to victim
 - Victim enters password
 - Hackers has password

What We Know About the Cyberattack on Democratic Politicians

By ALICIA PARLAPIANO AUG. 16, 2016

Officials say that Russian hackers may have breached the email accounts of more than 100 officials and groups. [RELATED ARTICLE](#)



Other Password Security Risks

- Keystroke loggers
 - Hardware
 - Software (spyware)
 - Wi-Fi-based pin extraction
- Shoulder surfing
- Broken implementations
 - E.g. TENEX timing attack



Recap

Three big problems

1. Weak passwords
2. Shared passwords
3. Phishing (giving passwords to the adversary)

Technical progress for shared passwords

Technical progress:

This progress is loosely informed by human-centered work.

- Hash
 - Store password hash, not plaintext
- Salt
 - Strengthen the password at storage level by adding randomness

But often more significant human-centered work is needed...

Usable security pipeline

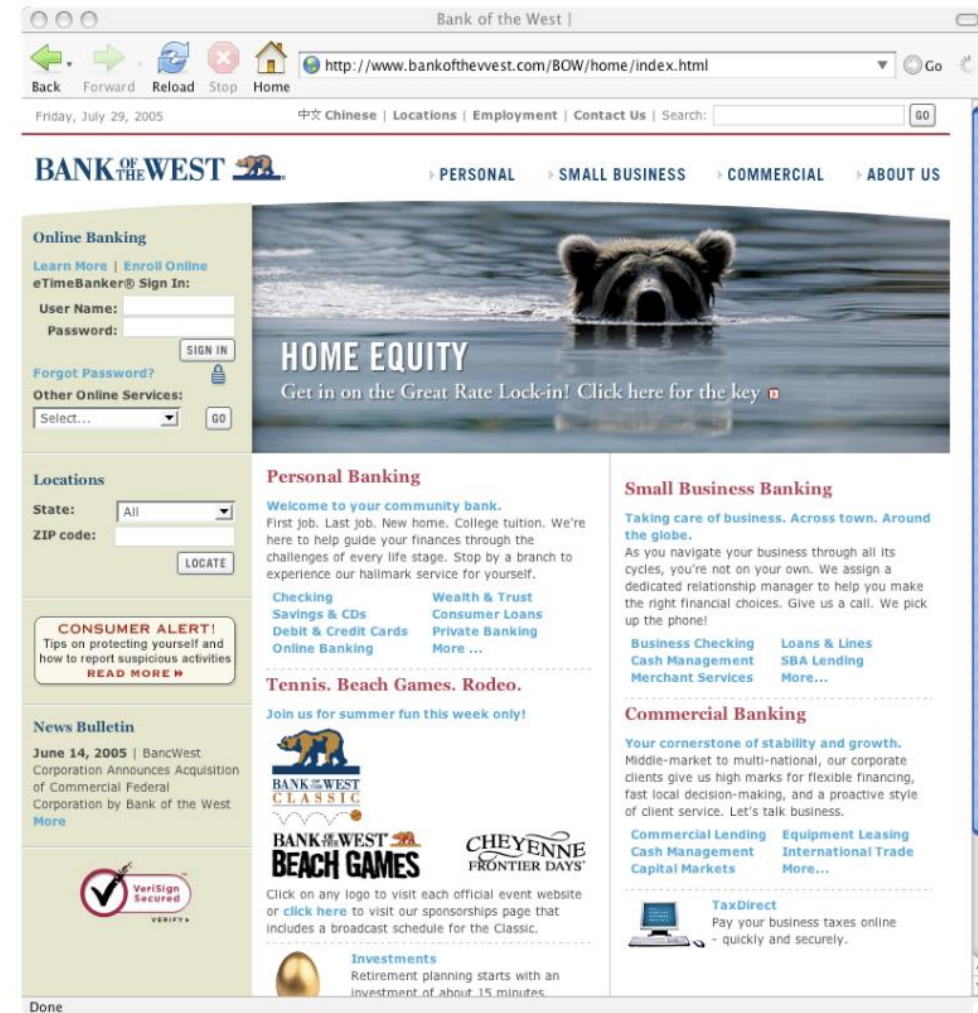
1. **Problematize:** Show the status-quo is bad
 1. Quantitative metrics are typically stronger
 2. But qualitative work is often needed to know what to measure
2. **Model:** Build a better model of human behavior
3. **Fix:** Design a better system to fix the status quo using this model

Usable S&P research on passwords

	Problematize	Model	Fix
Weak passwords	A Large-Scale Study of Password Habits <i>Florêncio & Herley, 2007</i>	Users Are Not the Enemy <i>Adams & Sasse, 1999</i>	Coming Monday <i>We'll cover fixes next class</i>
Shared passwords			
Phishing	Why Phishing Works? <i>Dhamija et al., 2006</i>		

Example: What makes phishing attacks successful?

- What makes a bogus website credible?
- Approach:
 1. Generate hypotheses from cognitive walkthrough of 200 known phishing attacks
 - Lack of knowledge
 - Visual deception
 - Lack of attention
 2. Present 22 users with 20 websites
 1. Identify real or fraudulent
 2. Rate confidence
 3. Explain reasoning



Example: What makes phishing attacks successful?

- Results
 - Good phishing websites fooled 90% of participants
 - 23% of participants did not look at visual security indicators (e.g., padlock)
 - Popup warnings about fraudulent website certificates were ineffective
 - 15 out of 22 participants ignored these
 - People are broadly vulnerable
 - Neither education, age, sex, previous experience, nor hours of computer use showed a statistically significant correlation with vulnerability to phishing.

More recent work on passwords & authentication

- Passwordless/FIDO2/passkeys
 - Example: Lassak, Pan, Ur & Golla, "[*Why Aren't We Using Passkeys? Obstacles Companies Face Deploying FIDO2 Passwordless Authentication*](#)" (USENIX Security 2024)
- Password managers
 - Example: Zibaei, Salehi-Abari & Thorpe, "[*Dissecting Nudges in Password Managers: Simple Defaults are Powerful*](#)" (SOUPS 2023)
- Cultural impact
 - Munyendo, Acar & Aviv, "[*In Eighty Percent of the Cases, I Select the Password for Them': Security and Privacy Challenges, Advice, and Opportunities at Cybercafes in Kenya*](#)" (IEEE S&P/"Oakland" 2023)
- Organizational/policy-level auditing
 - Lee, Sjöberg & Narayanan, "[*Password Policies of Most Top Websites Fail to Follow Best Practices*](#)" (SOUPS 2022)

Discussion

Next time:

- Authentication: Solutions
- Project proposals due in one week!